

PASO 2

INTEGRA

Infraestructura de Trazabilidad e Identidad para la Gestión de Recursos de Asignación

Arquitectura Técnica

Solución Blockchain + Ciberseguridad + IoT

Propuesta de implementación: Argentina — Modelo replicable para América Latina

Plataforma: ledger propio, con arquitectura de identidad y canales inspirada en Hyperledger Fabric · Estándar IoT: MQTT/TLS ·

Identidad: PKI X.509 (RSA-2048)

Nota de alcance: este documento describe tanto la arquitectura objetivo (la que fundamenta las decisiones de diseño) como el estado real del prototipo implementado. Donde ambas difieren, se indica explícitamente cuál es cuál — ver DECISIONES_DE_ALCANCE.md para el detalle completo de cada decisión de alcance.

1. Introducción y Objetivos de la Arquitectura

INTEGRA es la infraestructura técnica diseñada para responder con precisión al mapa de amenazas identificado en el Paso 1. La propuesta toma a Argentina — con la coordinadora nacional de trasplantes como organismo rector hipotético de referencia — como primer caso de implementación, pero cada decisión arquitectónica fue tomada pensando en la replicabilidad para otros países de Latinoamérica.

La arquitectura de INTEGRA se construye desde adentro del flujo de información, con seguridad por diseño (Security by Design) como restricción fundacional. Cada componente tiene un origen explícito en una amenaza documentada y responde a ella con precisión técnica.

1.1 Principios rectores del diseño

- **Security by Design:** la seguridad no es un módulo adicional, es una restricción de arquitectura desde el inicio
- **Zero Trust:** ningún actor, nodo ni dispositivo es confiable por defecto. Toda acción requiere verificación
- **Inmutabilidad como control:** el registro blockchain reemplaza la auditoría manual como mecanismo de accountability
- **Resiliencia operativa:** continuidad durante ataques en ventanas críticas de isquemia
- **Interoperabilidad controlada:** integración con sistemas legados sin ampliar la superficie de ataque
- **Mínimo privilegio:** cada rol accede únicamente a los datos y funciones estrictamente necesarios
- **Replicabilidad regional:** la arquitectura es parametrizable para adaptarse al marco institucional de cada país

2. Selección y Justificación del Modelo de Plataforma

El modelo de identidad, canales y consenso de Hyperledger Fabric se tomó como arquitectura de referencia porque resuelve directamente los vectores de amenaza identificados en el Paso 1: PKI nativa por organización, canales privados, y un modelo de red permissionada pensado para consorcios institucionales — exactamente el escenario de coordinadora nacional/hospitales/auditores que describe este proyecto.

Decisión de alcance: para esta fase del prototipo, INTEGRA implementa un ledger propio que reproduce ese modelo de identidad, canales y quorum, sin depender del runtime real de Hyperledger Fabric. La comparativa de esta sección fundamenta esa elección de diseño como arquitectura objetivo para una fase de producción institucional; no describe el motor que corre hoy. Detalle completo en DECISIONES_DE_ALCANCE.md.

2.1 Análisis comparativo de plataformas (arquitectura de referencia)

Criterio	Hyperledger Fabric	Ethereum (privado)	Quorum (JP Morgan)	Corda (R3)
Tipo de red	Permissionada ✓	Permissionada/pública	Permissionada	Permissionada
Control de identidad	PKI nativa + MSP por org ✓	Claves privadas, sin MSP	PKI + TLS mutual	X.509 por nodo
Confidencialidad	Canales privados por org ✓	Transacciones visibles X	Transacciones privadas (Tessera)	Solo entre partes involucradas
Rendimiento (TPS)	~3.000–10.000 TPS ✓	~100–300 TPS X	~500–1.500 TPS	~500 TPS
Integración médica	APIs REST + SDKs ✓	Web3.js / RPC	APIs REST	SDKs propietarios
Madurez en salud pública	Alta — antecedentes en salud pública internacional ✓	Baja en sector público X	Media — sector financiero	Media — sector financiero

2.2 Justificación por amenaza neutralizada — mecanismo real del prototipo

Amenaza (Paso 1)	Capacidad del modelo	Mecanismo técnico implementado
Insider manipula lista de espera (CRÍTICO)	Registro inmutable: cada transacción es irreversible y firmada digitalmente	Ledger append-only con hash-encadenado + política de endorsement obligatoria (2+ organizaciones)
Suplantación de identidad (Spoofing)	Identidad por organización: cada actor tiene certificado X.509 propio y verificable	PKI propia con CA por institución (RSA-2048)
Repudio de acciones	Toda transacción lleva firma criptográfica del actor. No repudiable por diseño.	Firma RSA-2048 en cada bloque. Timestamp verificable.
Exposición de datos clínicos	Canales privados: datos HLA solo visibles para partes autorizadas	Aislamiento por canal/proyección de lectura. Datos cifrados at-rest.
Ransomware / DoS	Red distribuida: ningún nodo único concentra el riesgo de escritura	Quorum de replicación (3 de 4 nodos) + orderer único de Fase 1 (ver 2.3) + nodos peer redundantes
Escalada de privilegios	RBAC nativo: roles definidos por atributos del certificado	Control de acceso por rol asociado al certificado de organización

2.3 Consenso y ordenamiento — estado real vs. objetivo

El mecanismo de consenso implementado hoy es un quorum de replicación (3 de 4 nodos deben confirmar un bloque para darlo por válido) combinado con un orderer único en coordinador nacional, que es quien decide la secuencia global de bloques para evitar forks por escritura simultánea de varios nodos.

Decisión de alcance: el orderer único de hoy es la Fase 1 del piloto, análogo a un líder fijo en un esquema de consenso tipo Raft, con elección dinámica de líder planificada para fases posteriores — coherente con la arquitectura objetivo de esta sección. No es un servicio de ordenamiento Raft real todavía. El umbral de quorum se fijó en 3 de 4 (no en 2 de 4) de forma deliberada: con una red de 4 nodos, un umbral de 2 permitiría que dos mitades de la red se reconozcan como mayoría sin comunicarse entre sí.

3. Arquitectura de Identidad Criptográfica

La identidad criptográfica es el fundamento de toda la arquitectura INTEGRA. En el piloto argentino, la PKI se ancla a la coordinadora nacional de trasplantes como autoridad raíz. En la expansión regional, cada país incorpora su propia CA raíz bajo un modelo de confianza federado.

3.1 Actores del sistema e identidad

Los cuatro nodos operativos del prototipo actual están marcados como "(nodo activo)". El resto son roles modelados en el diseño RBAC, con identidad y permisos definidos, pero no desplegados hoy como nodos independientes — se incorporan a medida que el piloto escala.

Actor	Tipo de identidad	Mecanismo de autenticación	Nivel de acceso (RBAC)
Coordinador nacional (nodo activo)	Certificado X.509 institucional	MFA: token TOTP + certificado cliente TLS	Lectura/escritura en lista de espera. Emisión de asignaciones firmadas. Orderer de Fase 1.
Coordinador provincial (nodo activo)	Certificado X.509 institucional	MFA: token TOTP + certificado cliente TLS	Lectura. Endorsement de transacciones según política (a confirmar alcance exacto con el equipo de desarrollo).
Hospital donante (nodo activo)	Certificado de organización (Org CA)	mTLS entre peers. Endorsement obligatorio.	Escritura de eventos clínicos propios en su canal.
Hospital receptor (nodo activo)	Certificado de organización (Org CA)	mTLS entre peers. Endorsement obligatorio.	Lectura de casos asignados. Confirmación de recepción firmada.
Médico trasplantador (rol, no nodo propio)	Certificado X.509 personal (CA hospitalaria)	MFA: biometría + PIN + certificado	Lectura de compatibilidad. Confirmación de trasplante. Sin modificación de lista.
Dispositivo IoT (contenedor)	Certificado de dispositivo (IoT CA)	TLS mutuo + token rotativo por sesión	Solo escritura de telemetría, firmada con RSA-2048. Sin lectura de datos clínicos.
Auditor externo (rol, no nodo propio)	Certificado de solo lectura, tiempo limitado	Certificado con atributo audit=true + expiración	Lectura total del ledger. Sin capacidad de escritura.
Sistema legado (HIS/EMR, rol conceptual)	Certificado de servicio (API Gateway)	OAuth 2.0 + mTLS entre gateway y nodo	Acceso controlado vía gateway. Sin acceso directo al ledger.
Organización candidata (pre-onboarding)	CSR: clave pública + datos de identidad, sin clave privada	No autentica transacciones clínicas. Solo es sujeto de la transacción org-join.	Ninguno hasta aprobación. No puede leer ni escribir en ningún canal.

3.2 Infraestructura de clave pública (PKI) — Modelo para Argentina

- **Root CA nacional:** operada por la coordinadora nacional de trasplantes. Emite certificados solo a CAs intermedias. En la expansión regional, cada país incorpora su propia Root CA bajo un modelo de confianza federado entre países.
- **CA por organización:** cada hospital y la coordinadora nacional operan su propia CA intermedia. Permite revocación localizada sin afectar a toda la red.

- **CA de dispositivos IoT:** CA especializada para el ciclo de vida de certificados de sensores. Rotación automática con TTL de 72 horas máximo.
- **Algoritmo criptográfico:** RSA-2048 para firmas de actores, organizaciones y dispositivos IoT — decisión de alcance documentada en DECISIONES_DE_ALCANCE.md (no ECDSA P-256).

3.3 Onboarding de nuevas organizaciones — transacción org-join

Incorporar un hospital nuevo a la red no es una operación de administración de usuarios: es una transacción de gobernanza sujeta al mismo patrón de endorsement N-de-M que rige la lista de espera. Esto evita dos fallas concretas de un modelo de "admin que asigna certificados": que la clave privada de la organización nueva pase por un servidor que no es el suyo, y que un solo actor tenga poder unilateral para admitir organizaciones enteras a la red.

- 1. La organización candidata genera su propio par de claves y un CSR (Certificate Signing Request) fuera de la red INTEGRA. La clave privada nunca sale de su infraestructura.
- 2. Envía el CSR como transacción org-join, que queda en estado pendiente.
- 3. La transacción requiere endorsement del coordinador nacional + al menos una organización ya activa en la red (mismo umbral N-de-M que WaitingListManager).
- 4. Antes de firmar, el proceso de CA (Root o intermedia — nunca los nodos clínicos ni el dashboard) valida el CSR: longitud y algoritmo de clave aceptados, y que el subject/CN no colisione con una organización ya existente.
- 5. Con endorsement válido y CSR sano, la CA emite el certificado. El resultado —alta o rechazo— queda registrado de forma inmutable en el ledger.
- 6. Un CSR rechazado también queda registrado como intento denegado. No desaparece sin dejar rastro.

Límite explícito: esta transacción resuelve la gobernanza de la incorporación — quién autoriza, cómo se valida, qué queda registrado. No automatiza la infraestructura técnica del nuevo nodo (contenedor, peers, trust store): ese paso operativo permanece manual en esta fase del piloto, por decisión de alcance documentada.

4. Smart Contracts — Chaincode y Lógica de Negocio

Los smart contracts (chaincode) transforman las reglas de asignación de órganos de texto administrativo a lógica ejecutable, auditada y no manipulable. Cada regla crítica del proceso se convierte en código que se ejecuta de forma determinista en todos los nodos.

Módulo	Función	Amenaza neutralizada (Paso 1)
DonorRegistry	Registro inmutable del donante: identidad, grupo sanguíneo, datos HLA, consentimiento. Solo escritura con firma del hospital emisor.	Spoofing de identidad de donante. Falsificación de datos de compatibilidad.
WaitingListManager	Gestión de lista de espera: cada modificación requiere endorsement de al menos 2 organizaciones y firma del actor. Toda entrada es inmutable.	Insider manipula lista de espera (Prioridad #2). Repudio de modificaciones.

Módulo	Función	Amenaza neutralizada (Paso 1)
CompatibilityEngine	Motor de compatibilidad HLA como chaincode inmutable. Reglas auditables, no modificables sin nuevo despliegue y consenso de la red.	Falsificación de compatibilidad HLA (Prioridad #3). Tampering de parámetros.
AssignmentContract	Emite la asignación de órgano con firma digital del coordinador. Inmutable, timestamped, no repudiable.	Repudio de asignaciones. Suplantación del coordinador nacional.
CustodyChain	Registra cada evento de la cadena de custodia: entrega, telemetría IoT, alertas de temperatura, recepción en destino.	Manipulación de tiempo de isquemia. Falsificación de cadena de custodia.
PostOpRegistry	Cierra el ciclo del trasplante: resultado quirúrgico, identificación del equipo. Hash de integridad del expediente clínico completo.	Alteración retroactiva de registros post-operatorio.
OrgRegistry	Gestiona el ciclo de alta de organizaciones: recibe el CSR, aplica la política de endorsement N-de-M, delega la emisión del certificado a la CA y registra de forma inmutable el resultado (alta o rechazo).	Admisión no autorizada de una organización a la red. Suplantación de identidad organizacional mediante CN duplicado.

4.1 Políticas de endorsement

- **Lista de espera (WaitingListManager):** requiere endorsement del coordinador nacional + al menos 1 hospital. Ningún actor individual puede modificar la lista solo.
- **Asignación de órgano (AssignmentContract):** requiere firma del coordinador + endorsement del hospital donante.
- **Datos de compatibilidad (CompatibilityEngine):** solo lectura en producción. El despliegue de nueva versión requiere consenso de 2/3 de las organizaciones miembro.
- **Cadena de custodia (CustodyChain):** escritura por dispositivo IoT autenticado, con endorsement del hospital que emite la custodia.
- **Alta de organización (OrgRegistry):** requiere endorsement del coordinador nacional + al menos una organización ya activa en la red. La emisión del certificado la realiza exclusivamente el proceso de CA — nunca los nodos clínicos ni el dashboard de gobernanza.

5. Integración IoT — Cadena de Custodia en Tiempo Real

El IoT en INTEGRA opera como evidencia forense en tiempo real. Los sensores en los contenedores de transporte generan un registro criptográfico de cada momento del traslado, eliminando la dependencia de reportes manuales susceptibles de alteración. En el prototipo actual, un simulador IoT genera una lectura de telemetría cada 5 segundos, firmada con RSA-2048.

5.1 Especificaciones de seguridad IoT

Control	Implementación técnica	Amenaza neutralizada
Autenticación de dispositivo	Certificado X.509 por dispositivo, emitido por CA IoT. TLS mutuo obligatorio.	Inyección de datos falsos desde dispositivos no autorizados.
Cifrado de telemetría	TLS 1.3 en tránsito. Cifrado en reposo en el gateway. Clave derivada del certificado.	Intercepción de comunicaciones IoT. Exposición de ruta de traslado.
Firma de datos en el edge	Cada lectura de sensor firmada con RSA-2048 antes de transmisión.	Tampering de datos de isquemia o temperatura durante el tránsito.
Rotación de credenciales	Certificados con TTL de 72h. Renovación automática vía protocolo EST.	Compromiso de credenciales IoT a largo plazo.

Control	Implementación técnica	Amenaza neutralizada
Alertas automáticas	Umbral en chaincode: temperatura fuera de rango, GPS sin señal, desvío de ruta, isquemia en límite.	Manipulación de cadena de frío. Desvío físico del traslado.
Operación offline	Gateway almacena hasta 24h de telemetría firmada. Transmite con evidencia de gap temporal al recuperar señal.	Pérdida de conectividad en zonas rurales.

5.2 Umbrales de alerta por tipo de órgano (diseño de referencia)

Órgano	Temperatura óptima	Isquemia máxima	Alerta crítica en blockchain
Corazón	0°C a 4°C	4–6 horas	A las 3h. Temperatura >4°C por más de 5 minutos.
Pulmón	0°C a 4°C	6–8 horas	A las 4h. Temperatura fuera de rango.
Hígado	0°C a 4°C	12–24 horas	A las 10h. Temperatura >5°C.
Riñón (caso piloto)	0°C a 4°C	24–36 horas	A las 20h. Temperatura fuera de rango sostenida.
Páncreas	0°C a 4°C	12–18 horas	A las 10h. Alerta de temperatura inmediata.

El riñón es el órgano seleccionado para el caso demostrativo del prototipo, por su mayor ventana de isquemia — facilita el testing sin presión de tiempo extrema.

6. Capas de Ciberseguridad por Nodo del Proceso — Arquitectura Objetivo

Nota de alcance: esta sección describe los controles de la arquitectura objetivo (SIEM, WAF, PAM, EDR). El prototipo actual implementa y valida el modelo de amenazas mediante 18 tests de seguridad automatizados (STRIDE) sobre el ledger, el endorsement y la PKI; no despliega todavía la infraestructura perimetral completa (SIEM/WAF/PAM como productos separados), que corresponde a una fase de hardening posterior sobre infraestructura institucional real.

Nodo	Riesgo (P1)	Controles de la arquitectura objetivo	Amenaza neutralizada
Hospital donante	CRÍTICO	MFA obligatorio (certificado + TOTP). Segmentación de red. Cifrado del transporte clínico. EDR en terminales.	Phishing, acceso físico, comunicación clínica en texto plano.
la coordinadora nacional de trasplantes (coordinación)	CRÍTICO	Mínimo privilegio estricto. PAM con grabación de sesiones. SIEM con alertas. Backup inmutable del ledger offline.	Insider malicioso, escalada de privilegios, movimiento lateral.
Sistema de asignación	CRÍTICO	Reglas de compatibilidad como chaincode inmutable. API Gateway con WAF. Rate limiting por actor.	Inyección en portales legacy, manipulación de parámetros.
Traslado del órgano	ALTO	Comunicaciones IoT cifradas TLS 1.3 con autenticación mutua. Datos de ruta solo visibles en canal privado.	Intercepción de ruta, compromiso de sensores IoT.
Hospital receptor	ALTO	Verificación criptográfica de la cadena de custodia antes de aceptar. MFA para confirmación de recepción.	Aceptación con documentación falsificada, sistemas legacy vulnerables.

7. Modelo de Gobernanza y Control de Acceso (RBAC)

7.1 Canales de comunicación

- **Canal principal:** accesible por todas las organizaciones. Asignaciones, custodia, registros post-operatorios. Datos anonimizados de donante.
- **Canal clínico:** solo el hospital donante, la coordinadora nacional y el hospital receptor del caso específico. Datos clínicos sensibles y compatibilidad HLA.
- **Canal de auditoría:** auditores con certificado de solo lectura. Registro completo de todas las transacciones.

7.2 Matriz de roles y permisos

Rol	Reg. donante	Lista espera	Ver compat.	Emitir asig.	Custodia IoT	Auditoría
Coordinador nacional	Lectura	Lect./Escrit. firmada	Lectura	Emisión firmada	No	Sí
Médico trasplantador	Lectura (su hospital)	Lectura	Lectura (su caso)	Confirmación	No	No
Hospital (institución)	Escritura propia	No	No	Endorsement	No	No
Dispositivo IoT	No	No	No	No	Escritura firmada	No
Auditor externo	Lectura	Lectura	Lectura	No	Lectura	Lect. total
Organización candidata	No	No	No	No	No	No — solo sujeto de una transacción org-join pendiente

8. Trazabilidad Amenaza → Control Técnico

La siguiente tabla cierra el ciclo entre el análisis de amenazas del Paso 1 y la arquitectura INTEGRA, con el mecanismo real del prototipo — no una referencia genérica a la plataforma objetivo.

Prior	Amenaza (Paso 1)	Score	Control INTEGRA (implementación real)	Componente
#1	Ransomware durante coordinación activa	9.8	Quorum de replicación (3 de 4 nodos) + orderer único de Fase 1 + IRP + backup offline.	Ledger propio + orderer + IRP
#2	Insider manipula lista de espera	9.8	WaitingListManager: endorsement de múltiples organizaciones + firma digital inmutable.	Chaincode + Endorsement Policy
#3	Falsificación de compatibilidad HLA	9.5	CompatibilityEngine inmutable. DonorRegistry con firma del hospital.	Chaincode + PKI + Canal clínico
#4	Ausencia de MFA en acceso crítico	9.5	MFA obligatorio: certificado X.509 (RSA-2048) + TOTP. TTL corto para IoT.	PKI + MFA
#5	Comunicación clínica sin cifrado	9.2	TLS 1.3 obligatorio para las comunicaciones entre nodos y con dispositivos.	TLS 1.3
#6	IoT sin autenticación	8.1	Certificado X.509 por dispositivo. TLS mutuo. Firma RSA-2048 en edge. Rotación cada 72h.	CA IoT + MQTT/TLS + Firma en edge
#7	IT tercerizado sin control	8.4	Acceso cero por defecto para proveedores. PAM con grabación de sesiones (arquitectura objetivo).	PAM + RBAC cero-confianza
#8	Sistemas legacy sin soporte	7.6	Aislamiento de red sin acceso al ledger. Integración solo vía API Gateway con validación.	API Gateway + Segmentación
#9	Admisión no autorizada / suplantación organizacional en onboarding	9.0 (estimado)	CSR sin clave privada + endorsement N-de-M + validación de CN único por la CA + registro inmutable de altas y rechazos.	OrgRegistry + CA + Endorsement Policy

Prior	Amenaza (Paso 1)	Score	Control INTEGRA (implementación real)	Componente
<i>Nota técnica: la arquitectura implementada corresponde a un ledger propio (no Hyperledger Fabric real), con firmas RSA-2048 (no ECDSA P-256) y un modelo de consenso por quorum de replicación con orderer único de Fase 1 (no un servicio Raft real). Estas son decisiones de alcance documentadas en DECISIONES_DE_ALCANCE.md, tomadas por restricciones de tiempo del prototipo, no por desconocimiento de la arquitectura objetivo — que sigue siendo Hyperledger Fabric con ordering service Raft para una fase de producción institucional. TLS 1.3 y MQTT v5 sí corresponden a las versiones realmente utilizadas. La arquitectura es parametrizable para su adaptación regional.</i>				